

NYC / AI AGENT SECURITY SUMMIT

Your Agent Escaped Without Escaping the Sandbox

Yossi Eliaz

Principal Engineer and Head of DevRel at Incredibuild.com

October 21, 2026

Four interfaces we gave the worker

```
credential  LAB_TOKEN=fixture-runner
files       bind /shared (writable)
publish     POST <allowed-host>/...
done        checker.py + expected.json
```

Inherited credentials. Dangerous mounts. Allowed endpoint. Verifier tampering.

Inherited credentials

```
Authorization: Bearer fixture-runner  
GET /projects/other/private  
200 {"fixture":"SYNTHETIC-PRIVATE-FIXTURE"}
```

```
Authorization: Bearer fixture-task  
GET /projects/other/private      403  
GET /input/parser-fix           200
```

Short-lived credential projection. Scope is this task.

Recorded Linux isolation run + factory

Dangerous mounts

```
Path("/shared/next-job.json").write_text('{"queue":"attacker"}')
```

```
writable bind    WRITE_SUCCEEDED    host file changed  
read-only bind  WRITE_DENIED        host file unchanged
```

```
Path("/output/patch.txt").write_text("legitimate patch output")  
# succeeds in both cases
```

Capability-scoped filesystems: /input ro, /output rw.

Recorded Linux isolation run + factory

Exfiltration through an allowed endpoint

```
POST /accounts/other/uploads
{"data":"SYNTHETIC-PRIVATE-FIXTURE"}
201
```

```
request = {"operation":"publish_report","task":"parser-fix"}
# extra keys -> DENIED, no delivery
# broker POST /accounts/team/reports
#           {"task":"parser-fix","status":"completed"}
```

Process isolation: worker cannot reach the service. Broker owns the POST.

Recorded Linux isolation run + factory

Verifier tampering

```
# checker.py  hash unchanged
expected = json.loads(Path("expected.json").read_text())
```

```
# worker-written expected.json
{"input": "admin:none", "output": 200}
```

```
python3 handler.py admin:none
200      # shipped
401      # required
CI       PASS
```

The worker edited the cases. The checker file did not change.

Recorded Linux isolation run + factory

Close each one

```
token = mint(scope=task, ttl=1h)           # credential projection
mount /input ro; mount /output rw          # scoped filesystem
unshare-net; broker.publish(team_report)    # process isolation
frozen = freeze(handler.py)
judge(frozen, controller_cases)
publish(frozen)                             # live swap -> DENIED
```

History: rewritten log => different chain head. The compare decides merge.

Recorded Linux isolation run + factory

Four boundaries

```
credential  = ?      # what else can it read?  
mounts      = ?      # writable? forked tomorrow?  
POST        = ?      # who sets path and body?  
compare     = ?      # can the worker edit cases or PASS?
```

403, EROFS, DENIED, reject must come from outside the worker.

RECORDED RESULTS ON GITHUB

Who gave this process the authority?

github.com/zozo123/nyc-talk

Appendix / Commands

```
make factory      # freeze, judge, gate  
make demo         # Linux isolation lab  
make deck         # this PDF
```

29 lab checks passed, 6 factory checks passed.

Appendix / Limits

Synthetic fixtures. Deterministic worker scripts.

Five /admin cases cover this policy.

Twenty-nine lab checks are recorded assertions, not twenty-nine CVEs.

Appendix / Links

github.com/zozo123/nyc-talk

Script, slides, recorded results

AI Agent Security Summit, NYC